

Key Takeaways: CIA Fundamentals

Estimated time needed: 5 minutes

Here are some key takeaways from the Fundamentals of Confidentiality, Integrity, and Availability video.

Confidentiality

There are two components or technologies involved in ensuring confidentiality, Access Control and encryption. Let's review each of these.

Access Control

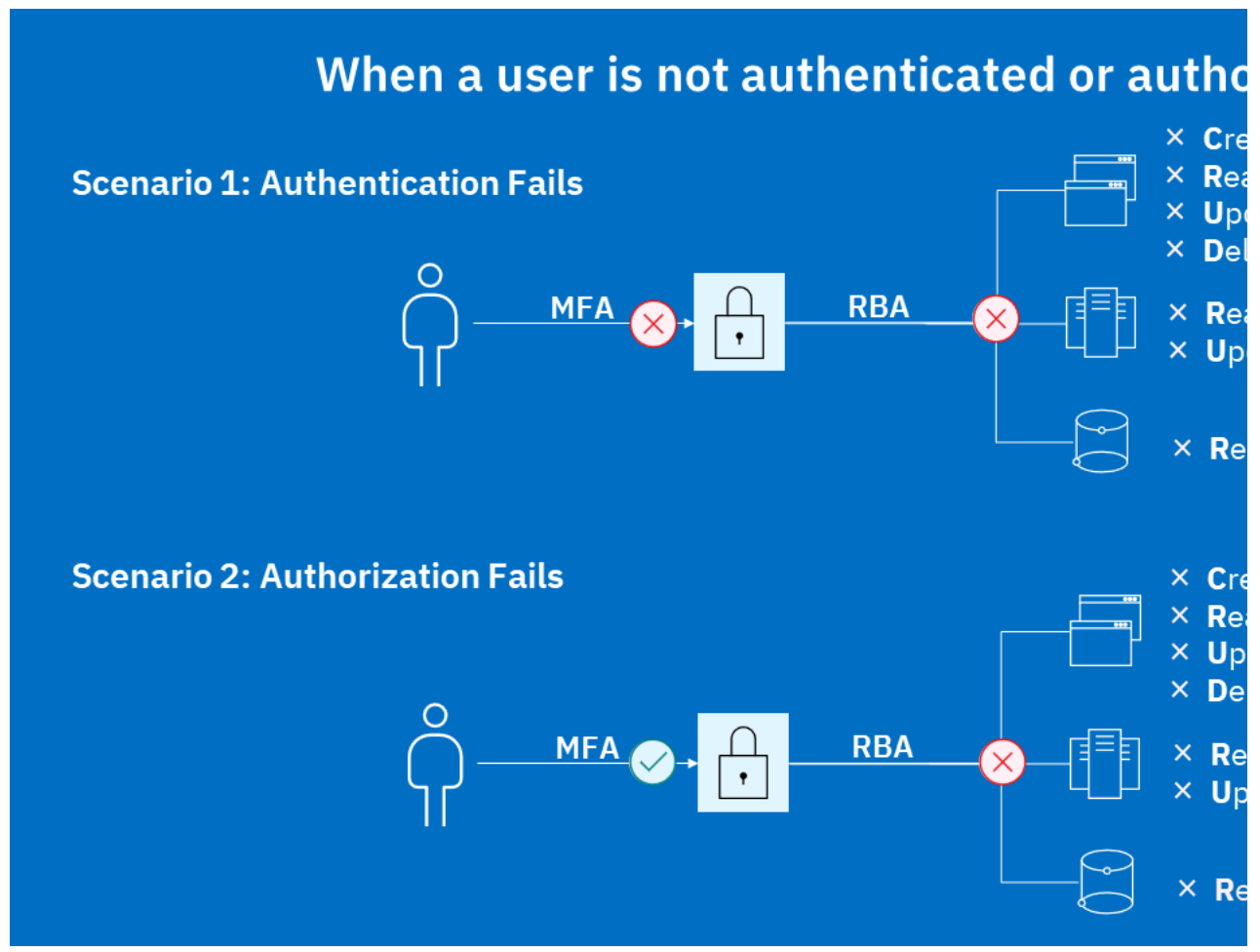
Access Control consists of authentication and authorization. Authentication answers the question "Who are you?" Authorization answers the question "Are you allowed to do this or not?" If both checks pass, the user is allowed to access the assigned resources.

Scenario	Example
The image to the right summarizes the scenario when an authorized user logs into a system where multifactor authentication (MFA) is implemented for user authentication and role-based access (RBA) is implemented for authorization. After successful authentication, the user can access different applications, servers, and databases based on role-based access authorization.	For an Authorized User MFA ✓ 🔒 RBA ✓ ✓ Create ✓ Read ✓ Update ✓ Delete ✓ Read ✓ Update ✓ Read Authentication Who are you? Authorization Are you allowed to do this or not?

For the unauthorized users, there are two scenarios:

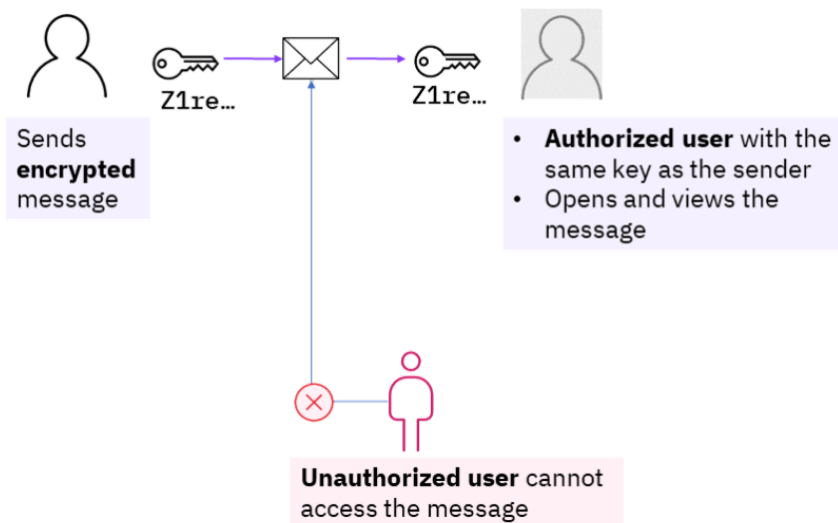
- If the user is neither authenticated nor authorized
- If the user is authenticated but not authorized

In either scenario, the user will not be able to access the unauthorized items.



Encryption

Encryption is a way to accomplish confidentiality. The image depicts an example using encryption. When a message is encrypted, only authorized users with the key can open it. Unauthorized users may receive the message but will not be able to view the contents.



Integrity

Integrity is a quality that says a message is true to itself, a transaction is true to itself. If it gets modified, we can detect it and if detected, we will recognize that this should not happen and will take a counter measure.

For example, a user should not be allowed to modify or update system logs or blockchain should not be modified.

Cryptographic technologies like Digital Signature and Message Authentication Code (MAC) are used to detect and block any attempt to modify logs or data.

Availability

Availability means that authorized users should be able to access systems and resources when they need it.

Availability is impacted by Denial of service (DoS), where an attacker clogs the resources, which results in the service being denied to an authorized user. Other variations of DoS include:

- **Distributed denial of service (DDoS)**, where an attacker not only clogs the server from their own system but also from other systems that they have gained control over.
- **SYN flood**, where an unauthorized user reserves a resource, referred to as a session. On receipt of an acknowledgement, the user goes silent on this session. However, another session is started blocking another resource and this continues till all resources are blocked.

Result: Authorized users cannot access the required service or resource!

Important: Make sure that the system is up and available to authorized users when they need it.

Summary

When working on an IT project, one of the things to do is to cover all your bases, which you can confirm if answers to the following questions are YES.

- Have I met the confidentiality requirements of the project?
- Is the sensitive data only available to those who are authorized to see it?
- Is this system true to itself?
- Do I have integrity checking so that if someone modifies it or tampers with it, I can be aware of that and know to adjust my trust level?
- Do I have the system available all the time that it's supposed to be available?

Author(s)

Dee Dee Collette



Skills Network